



snap – Installazione e avvio da zero

Documento operativo. Porta da una macchina vuota a un sistema che scansiona: console, sonda, perimetro. Ogni passo ha una verifica: se la verifica non dà il risultato indicato, non si prosegue – si risolve, e il capitolo 9 raccoglie i guasti che si incontrano davvero, con la causa misurata.

13/09/2026 21:44

Documento operativo. Porta da una macchina vuota a un sistema che scansiona: console, sonda, perimetro. Ogni passo ha una verifica: se la verifica non dà il risultato indicato, non si prosegue – si risolve, e il capitolo 9 raccoglie i guasti che si incontrano davvero, con la causa misurata.

Riferimenti	
Sorgente	16_INSTALLAZIONE_DA_ZERO.md
Prodotto	snap - Secure Network Assessment Platform

Contenuto del documento
1. Che cosa si sta installando
2. Prerequisiti
3. La console
4. La sonda in contenitore (Linux)
5. La sonda fuori dal contenitore (Windows)
6. Registrare la sonda
7. Il perimetro
8. Verifica finale
9. 8-bis. L'agente sulle macchine (facoltativo)
10. Guasti che si incontrano davvero
11. Riferimenti

Documento generato dal sorgente in docs/: se il contenuto cambia, cambia il sorgente e questo PDF si rigenera. Una copia modificata a mano sarebbe una seconda verità'.

13/09/2026 21:44 · periodo di riferimento: procedura di installazione

PRODOTTO	SNAP – SECURE NETWORK ASSESSMENT PLATFORM
Versione documentata	console 1.8.0, sonda 1.3.0, agente 1.2.2
Conformità documentale	ISO/IEC/IEEE 29148:2018 (§ scopo, riferimenti, istruzioni)
Destinatari	chi installa il sistema e chi lo assiste

1. Che cosa si sta installando

Due componenti distinti, che si parlano in una sola direzione.

COMPONENTE	DOVE VA	CHE COSA FA
Console (server)	sulla rete di gestione	raccoglie l'inventario, lo presenta, invia notifiche e report
Sonda (probe)	dentro la rete da esaminare	esegue le scansioni e conferisce i risultati alla console
Agente (facoltativo)	sulle macchine da sorvegliare da dentro	riferisce alla sonda ciò che dalla rete non si vede: accessi falliti, utenze nuove, protezioni disattivate, processi in ascolto, dischi che finiscono (capitolo 8-bis)

La console non raggiunge mai la sonda. È la sonda che apre la comunicazione, ogni quindici secondi, e nella risposta riceve configurazione e comandi. È una scelta di progetto: nella rete di un cliente non si apre un canale in ingresso.

La stessa regola vale un piano più sotto: l'agente apre lui verso la sonda, e la sonda non lo chiama mai. Chi sta più in basso apre verso chi sta più in alto, e nessuno dei tre chiama indietro: una macchina in rete di utenza non deve essere raggiungibile da nessuno, nemmeno dal prodotto che la sorveglia.

Conseguenza pratica da conoscere subito: i comandi dalla console arrivano alla sonda entro un minuto, non istantaneamente, e la console mostra l'ultima istantanea consegnata, non lo stato dal vivo. Entrambe le cose sono dichiarate nelle pagine.

2. Prerequisiti

REQUISITO	SERVE A	SE MANCA
Docker con Compose v2	console e basi dati	niente si avvia
Python ≥ 3.12	sonda fuori dal contenitore (Windows)	solo per quella variante
nmap ≥ 7.80	la sonda: è lo strumento che esamina la rete	nessuna scansione; l'interfaccia lo dichiara
Npcap (solo Windows)	socket raw: scansione SYN e rilevamento del sistema operativo	la sonda ricade sulla scansione per connessione, più lenta e senza sistema operativo
Certificato TLS per la console	la console non parla in chiaro	il proxy non parte
Porte 5500-5600 libere	vincolo di progetto sulle porte	conflitto all'avvio

Dove va la sonda: la decisione che conta

SITUAZIONE	VARIANTE DA USARE
Sonda su Linux	contenitore, network_mode: host – l'esercizio normale
Sonda su Windows/Mac con Docker Desktop	fuori dal contenitore (start-nativa.ps1)

Non è una preferenza. Su Docker Desktop i contenitori non stanno sull'host ma dentro una macchina virtuale, e il NAT di quella macchina risponde per ogni indirizzo. Misurato sulla stessa subnet nello stesso momento:

dal PC `nmap -sn 10.10.60.0/24 -> 5 host attivi`

dentro il contenitore `nmap -sn 10.10.60.0/24 -> 256 host attivi su 256`

Una sonda in quelle condizioni non fa inventario: lo inventa – 251 nodi inesistenti, con porte e classificazioni che sembrano lavoro fatto. Il prodotto oggi se ne accorge e rifiuta la scoperta, ma il rifiuto è un allarme, non una soluzione.

3. La console

Configurazione

```
cd docker/server
```

```
cp .env.example .env
```

Nel file .env vanno compilate cinque voci; le altre hanno un valore predefinito.

VOCE	CHE COS'È
SNAP_SERVER_SECRET_KEY	chiave delle sessioni. Casuale, lunga, mai riusata
POSTGRES_PASSWORD	password del proprietario della base dati: crea e migra lo schema
SNAP_PG_APP_PASSWORD	password dell'utenza applicativa: legge e scrive i dati, non cambia la struttura
SNAP_HTTPS_PORT	porta pubblica della console (predefinita 443)
SNAP_SYSLOG_PORT	porta del collettore syslog, se si usa il SIEM (predefinita 514)

Le due utenze di base dati sono distinte per minimo privilegio: l'applicazione non deve poter alterare lo schema. Una chiave di sessione si genera così:

```
python -c "import secrets; print(secrets.token_urlsafe(48))"
```

Certificato

```
mkdir certs
```

```
openssl req -x509 -newkey rsa:4096 -sha256 -days 730 -nodes \
-keyout certs/server.key -out certs/server.crt \
-subj "/CN=snap.example.local" \
-addext "subjectAltName=DNS:snap.example.local,IP:10.20.10.42"
```

Il subjectAltName deve contenere l'indirizzo con cui si aprirà la console. I browser ignorano il CN da anni: senza il SAN giusto la console risulta «Non sicura» anche con il certificato installato — e in quello stato Chrome ed Edge rifiutano di offrire il salvataggio delle credenziali.

Se il certificato è autofirmato, per togliere l'avviso va reso attendibile sulle postazioni:

```
Import-Certificate -FilePath "docker\server\certs\server.crt" `
-CertStoreLocation Cert:\LocalMachine\Root
```

Avvio

```
.\start.ps1 # Windows
./start.sh # Linux
```

Lo script verifica i presupposti, costruisce l'immagine e avvia i tre servizi: snap-postgres, snap-server, snap-proxy.

Verifica. Tutti e tre devono risultare healthy:

```
docker ps --format "{{.Names}}\t{{.Status}}"
```

e la console deve rispondere in HTTPS:

```
curl -k -o /dev/null -w "%{http_code}\n" https://<indirizzo>/
```

Un 302 è l'esito atteso: è il rimando alla pagina di accesso.

Primo accesso

Le credenziali iniziali sono nel .env (SNAP_BOOTSTRAP_ADMIN_*). Al primo accesso la console chiede di cambiare la password.

Poi, in Amministrazione > Impostazioni:

- Indirizzo pubblico della console (public_url): è quello che le sonde useranno per registrarsi e che finisce nei collegamenti dei messaggi. Se la console è in HTTPS deve iniziare per https://.
- Canali di recapito: server di posta e, se si usa, il bot Telegram. Senza posta configurata le notifiche restano in coda e i pulsanti che spediscono lo dichiarano.

4. La sonda in contenitore (Linux)

```
cd docker/probe
cp .env.example .env
```

Da compilare: SNAP_PROBE_SECRET_KEY, PROBE_POSTGRES_PASSWORD, PROBE_PG_APP_PASSWORD. Poi il certificato in

./certs/probe.crt e probe.key, con le stesse regole del capitolo 3.2.

Se la console ha un certificato proprio, va messo il suo certificato (mai la chiave privata) in ./trust/ e dichiarato:

```
SNAP_PROBE_SERVER_CA=/etc/snap/trust/server-ca.crt
```

Senza, la sonda rifiuta di parlare con la console – ed è il comportamento giusto: su quel canale passano le chiavi della registrazione e l'inventario della rete. Non esiste un interruttore per disattivare la verifica.

```
docker compose up -d --build
```

Verifica. snap-probe, snap-probe-proxy e snap-probe-postgres healthy, e l'interfaccia della sonda che risponde su https://127.0.0.1:5510 dalla macchina della sonda.

5. La sonda fuori dal contenitore (Windows)

La base dati resta in contenitore; la sonda gira sulla macchina, dove vede le interfacce vere. Il TLS resta davanti: la sonda ascolta in chiaro solo sul proprio loopback e un nginx in contenitore termina il TLS sulla 5510.

```
rete --HTTPS--> proxy-nativa (contenitore) --loopback--> sonda:5511
```

Avvio

```
cd docker\probe
copy .env.example .env # e compilare come al capitolo 4
docker compose -f docker-compose.yml -f docker-compose.nativa.yml up -d postgres
proxy-nativa
.\start-nativa.ps1
```

start-nativa.ps1 verifica i presupposti prima di avviare: file di configurazione, nessuna sonda in contenitore già attiva, base dati raggiungibile, nmap nel PATH, proxy TLS in esecuzione, ancora di fiducia verso la console.

Così la sonda resta legata alla finestra: chiuderla la ferma. Per avviarla senza finestra, come si conviene a un servizio:

```
.\start-nativa.ps1 -Nascosta
```

Lo script si rilancia in un processo nascosto e restituisce subito il prompt. Il diario finisce in probe\sonda-nativa.log (e gli errori in .log.err), e si sovrascrive a ogni avvio: è il diario della sessione corrente, non un archivio -- lo storico sta nell'interfaccia della sonda.

Senza finestra non c'è più un Ctrl+C da premere, e per fermarla c'è un comando:

```
.\stop-nativa.ps1 # ferma agente e interfaccia
.\stop-nativa.ps1 -ConIContenitori # ferma anche proxy TLS e archivio
```

stop-nativa.ps1 ferma prima l'agente, poi l'interfaccia: all'inverso resterebbe un agente che continua a prenotare bersagli senza che nessuno possa vedere che cosa sta facendo.

Per sapere che cosa fermare guarda due cose, in quest'ordine:

- 1. il registro dei processi probe\sonda-nativa.pid, che l'avvio scrive con i PID che ha creato;
- 2. la riga di comando, come rete di sicurezza per ciò che è stato avviato a mano.

Il registro non è un vezzo: su Windows la riga di comando di un processo non è sempre leggibile – basta che appartenga a una sessione chiusa – e un arresto che cercasse solo lì lascerebbe in vita un agente vecchio. Due agenti sullo stesso archivio si contendono le prenotazioni dei bersagli, ed è il guasto che l'avvio verifica.

Alla fine lo script controlla che i processi siano davvero spariti e, se qualcuno è sopravvissuto, lo dice con il suo PID: succede quando il processo appartiene a una sessione chiusa, e in quel caso va fermato da una finestra amministratore

```
Stop-Process -Id <i PID elencati> -Force
```

prima di riavviare, o si avranno due agenti sullo stesso archivio.

Privilegi. Aperta come utente normale, la sonda non può usare la scansione SYN (-sS) né il rilevamento del sistema operativo (-O): ricade sulla scansione per connessione, più lenta e senza sistema operativo, e lo dichiara nella propria pagina di stato. Per l'inventario completo va aperta come amministratore.

Non avviare mai anche snap-probe. Due sonde sullo stesso archivio si contendono le prenotazioni dei bersagli e lo stato dei nodi diventa incoerente. Lo script lo verifica e si ferma.

La prima password

L'interfaccia della sonda è protetta da una sola password, scelta alla prima apertura, e si sceglie dalla postazione della sonda: dalla rete la scelta iniziale è rifiutata, così la sonda appartiene a chi l'ha installata e non al primo che la trova.

Fuori dal contenitore c'è un passaggio in più, e va fatto una volta sola:

```
.\start-nativa.ps1 -PrimaPassword
```

Poi si apre `http://127.0.0.1:5511/primo-accesso` da quella macchina, si sceglie la password, si ferma e si riavvia in modo normale. Senza quell'interruttore il cookie di sessione è marcato Secure, non viene rimandato su HTTP e la pagina risponde «il token di sicurezza è scaduto» a ogni tentativo.

Interfaccia di uscita delle scansioni

Su una macchina con più interfacce, nmap sceglie dalla tabella di instradamento del sistema — e la tabella può essere sbagliata. Misurato su un'installazione reale:

```
0.0.0.0/0 metrica 40 gateway 10.10.60.1 <- Wi-Fi SPENTO, senza indirizzo
```

```
0.0.0.0/0 metrica 55 gateway 10.20.10.1 <- la LAN vera, attiva
```

La rotta migliore era quella di un'interfaccia spenta: le scansioni uscivano da lì, e l'esito era incoerente senza che nulla lo dicesse. Si dichiara in `.env`:

```
SNAP_PROBE_SCAN_INTERFACE=eth7 # il nome che usa nmap: nmap --iflist
```

```
SNAP_PROBE_SCAN_SOURCE_IP=10.20.10.42
```

Vale con i socket raw. Senza di essi la scansione passa dallo stack del sistema e torna a subire la rotta sbagliata: là il difetto va corretto nella tabella di instradamento della macchina, non nel prodotto.

6. Registrare la sonda

- 1. Sulla console: Sonde > Registra sonda. Si ottiene un pacchetto SNAP1-....
- 2. Sull'interfaccia della sonda: Registrazione, si incolla il pacchetto.
- 3. La sonda scambia le chiavi, riceve la configurazione e compare in Sonde > Flotta sonde come attiva.

Verifica. Nella flotta la sonda risulta attiva e il battito è recente. Dal bottone arancione si apre la sua console remota: mostra quello che si vedrebbe stando davanti alla sonda, compreso il diario locale.

7. Il perimetro

Senza perimetro la sonda non ha bersagli: resta attiva e non scansiona nulla.

Rete > Perimetro > Importa: un file di testo con una subnet per riga (10.20.10.0/24 Sede centrale). Il perimetro è dichiarato sulla console e consegnato alla sonda nella configurazione cifrata: la sonda rifiuta qualunque bersaglio che non vi sia contenuto.

Per ogni subnet si dichiarano poi:

- Zona di rete — il contesto che decide se un'esposizione è un problema. Vuota vale come rete di utenza, cioè il giudizio più severo: il silenzio non deve valere come giustificazione.
- Senza fili — non è un'etichetta: cambia il modo in cui la sonda osserva quella rete. Su Wi-Fi un apparato resta agganciato minuti, e una passata ogni tre giorni non lo vede mai; con l'interruttore attivo la sonda fa una ricognizione ogni due minuti.

Verifica. Entro pochi minuti Rete > Dispositivi comincia a popolarsi, e il diario della sonda mostra le fasi (discovery, raffica, ports, services...).

8. Verifica finale

CONTROLLO	ESITO ATTESO
<code>docker ps</code>	tutti i servizi healthy
Console in HTTPS	pagina di accesso, senza avviso di certificato
Sonde > Flotta	sonda attiva, battito di meno di un minuto fa
Sonde > Console	istantanea recente, diario che scorre
Rete > Dispositivi	nodi con porte, servizi e sistema operativo

CONTROLLO	ESITO ATTESO
Diario della sonda	fasi diverse nello stesso ciclo, non una sola ripetuta

Un segnale da riconoscere subito: una fase che finisce sistematicamente in pochi secondi con zero record non è una fase veloce, è una fase che non ha funzionato. Il diario dice quanti compiti sono partiti, non quanto dato hanno prodotto: i due numeri vanno letti insieme.

9. 8-bis. L'agente sulle macchine (facoltativo)

Si fa dopo che la sonda scansiona e conferisce: l'agente aggiunge una vista, non la sostituisce. Va installato solo dove serve davvero – server, macchine critiche, postazioni sensibili – non ovunque per abitudine.

Sulla console della sonda, pagina Agenti: si scrive a che cosa serve il token e si preme Emetti un token. Il token si vede una volta sola e vale un'ora.

Sulla macchina da sorvegliare:

```
pip install psutil
```

```
python snap_agent.py registra https://<sonda>:5510 <token>
```

```
python snap_agent.py prova # mostra che cosa manderebbe, senza mandarlo
```

```
python snap_agent.py servizio # a regime, sotto systemd o attività pianificata
```

VERIFICA	ESITO ATTESO
https://<sonda>:5510/api/agent/ping	{"protocollo": "SNAP-AGENT/1", "pronto": true}
Console della sonda, Agenti	la macchina compare con stato attivo e un invio recente
Console del server, IDS > Agenti di macchina	la stessa macchina, con CPU, memoria e dischi

Se la macchina compare sulla sonda ma non sul server, il problema non è l'agente: è il conferimento della sonda, e si guarda in Sonde > Console.

Una cosa da sapere prima di guardare le rilevazioni. Le regole dell'IDS che si fondano sull'assenza di memoria non scattano nelle prime dodici ore dalla prima osservazione: il motore costruisce la linea di base e tace. La pagina lo dichiara in un avviso. È voluto – un IDS che al primo avvio segnala l'intera rete viene disattivato il giorno dopo.

10. Guasti che si incontrano davvero

SINTOMO	CAUSA	RIMEDIO
400 Bad Request – The plain HTTP request was sent to HTTPS port	si è aperto http:// su una porta TLS (il browser lo assume su porte non standard)	dalla 1.5.0 il proxy rimanda da solo
Il browser non offre di salvare la password	la pagina ha un errore di certificato: in quello stato i browser lo rifiutano	rendere attendibile il certificato; SAN con l'indirizzo usato
certificate verify failed: self-signed certificate nella sonda	manca l'ancora di fiducia verso la console	certificato della console in ./trust/ (capitolo 4)
conflicting options: custom host-to-IP mapping and the network mode	extra_hosts insieme a network_mode: service:	risolto dalla 1.5.0: variabile SONDA_HOST
Archivio non ancora pronto, in ciclo	la base dati ascolta solo sul proprio loopback e la porta pubblicata non lo raggiunge	usare il compose della variante nativa
La subnet mostra tutti gli indirizzi attivi	sonda dietro il NAT di Docker Desktop	eseguire la sonda fuori dal contenitore (capitolo 5)
La sonda è attiva ma non scansiona	perimetro vuoto, subnet disattivate, o scansioni sospese	capitolo 7; la pagina Perimetro mostra il numero di subnet attive
Nodi «in lavorazione» fermi per ore	una fase monopolizza il ciclo	verificare nel diario che le fasi si alternino
L'agente riceve 403 alla registrazione	il token è scaduto (vale un'ora), è già stato usato, o è stato ricopiato male	emetterne un altro dalla pagina Agenti della sonda



SINTOMO	CAUSA	RIMEDIO
L'agente riceve 401 a ogni invio	firma, marca temporale o nonce non accettati. Il rifiuto non dice quale: il motivo per esteso è nel diario della sonda	se dice «marca temporale fuori finestra», l'orologio della macchina è sfasato di più di cinque minuti: sincronizzarlo
La pagina IDS mostra zero rilevazioni	nelle prime dodici ore è l'esito atteso (memoria in apprendimento); dopo, si guarda Regole e sensori	un sensore non disponibile non produce rilevazioni, e il suo zero non è una buona notizia

11. Riferimenti

DOCUMENTO	CONTENUTO
PORTS.md	quale porta a quale servizio, e perché
docs/05_MANUALE_OPERATIVO.md	uso quotidiano di console e sonda
docs/14_MOTORE_DI_SCANSIONE.md	come lavora la scansione, con le misure
docs/09_REGOLE_CANALI_MANUTENZIONE.md	notifiche, conservazione, copie
docs/17_IDS_E_AGENTI.md	IDS e agenti: decisioni, regole, casi d'uso commentati
Guida in applicazione (/guida/)	la stessa materia, dentro la console